LABORATUVAR 6 · EFO MAKİNA · BESLEME BANDI & SARSAK

CRA Incident Simulation

Çıktı: Incident Workflow

AD SOYAD	GRUP	EVİDENCE PACK	MAKİNE
Yağız Enes Doğan	Gündüz - B	EP 13 Incident Response	Efo Makina · Besleme Bandı & Sarsak (Titreşimli Konveyör)

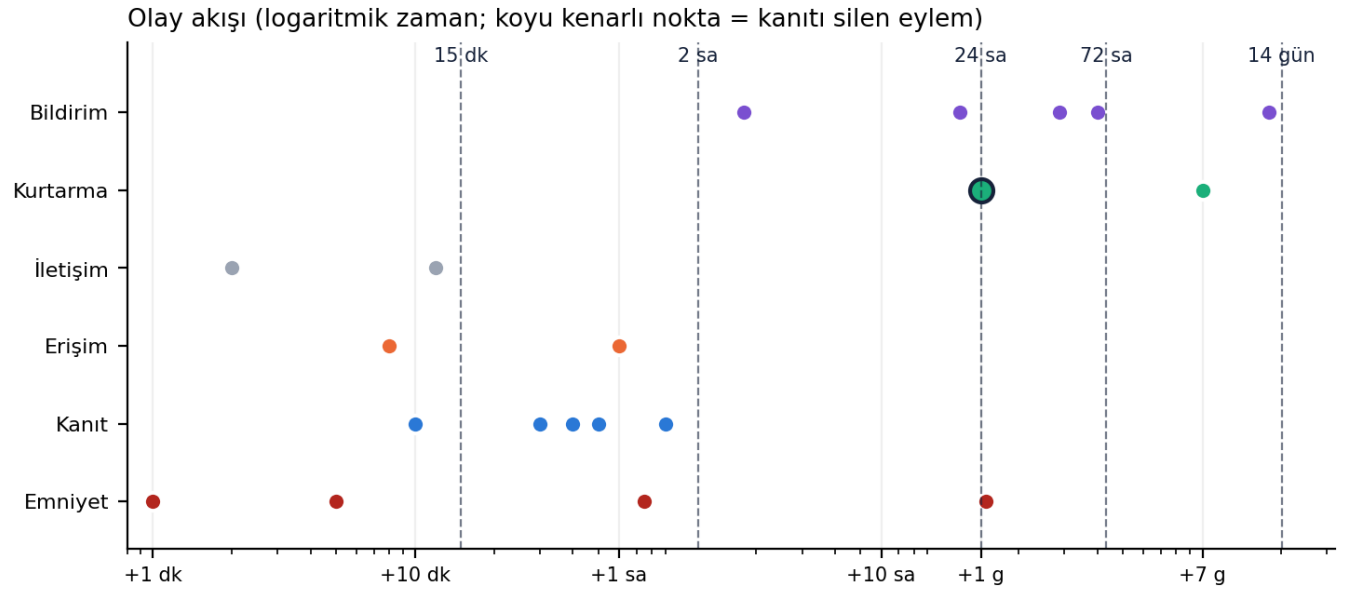
Bağımsız akademik çalışmadır; Efo Makina ile bağlantısı yoktur. Analizin birçok kısmı varsayıma dayanır ve gerçek ürünün emniyet durumu hakkında bir iddia değildir.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıttır**. CRA'nın 24 sa / 72 sa / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır; ezber değil.

Efo bağlamı: Senaryo (Efo uyarlaması, V19): Saat 10:15. Üreticinin paylaşılan servis hesabıyla, sürekli açık 4G router üzerinden gece 03:00'te tanınmayan bir konumdan giriş yapıldığı görüldü. PLC konfigürasyonu değişmiş olabilir; acil stopun durma mesafesi henüz doğrulanmadı. Makine çalışıyor. Vardiya sorumlusu sizsiniz. Senaryo, PaketPro sürümündeki olayın (gece girişi, doğrulanmamış ışık perdesi parametreleri) Efo'ya aktarılmış hâlidir; mevcut mimari LAB 4'teki varsayımdır (V5).

Kim bildirir? CRA'nın bildirim yükümlülüğü **üreticiye** aittir: Efo, dijital eleman içeren makineyi AB pazarına arz ettiyse Efo; açık PLC'nin kendisindeyse PLC üreticisi [Y22] ÇIKARIM. Vardiya sorumlusu bildirimi yapmaz. Ama bildirimin dayanacağı her bilgi onun ilk iki saatte koruduğu kanıttan gelir. CRA süresi, üreticinin olayı **öğrendiği andan** başlar. Bu akışta Efo +00:12'de aranıyor; çizelge yine de 10:15'ten sayıldı, yani ihtiyatlı.

Görev — zaman çizgisini doldurun



1 10:15 — ilk 15 dk: Kimi ararsınız? İlk üç eyleminiz?

Kimi ararım:

1. Bakım / otomasyon sorumlusu: hattı durdurup kilitleyecek ve konfigürasyonu okuyacak kişi.
2. İSG uzmanı: emniyet kararı onun onayı olmadan kapanmaz.
3. BT/OT güvenlik sorumlusu (ya da dış destek): kanıt toplama.
4. Üretici (Efo): servis hesabı onların. **Bilinen telefon numarasından** aranır; ele geçirilen kanal (uzak bağlantı, o hesaba bağlı e-posta) kullanılmaz.

Ciddi bir olayda ulusal başvuru noktası USOM'dur [Y30] SEKTÖR-TİPİK.

İlk üç eylem:

1. **Önce emniyet:** Bant başındaki operatör besleme ağzından uzaklaştırılır. Hat **normal stop ile kontrollü durdurulur** ve ana şalter kilitlenir (LOTO). **Reset yok.** Neden durduruyoruz: mevcut mimaride acil stop PLC'den ve invertör rampasından geçiyor (LAB 4). PLC değiştiyse acil stopa güvenilemez. Q2'deki doğrulama bu kararın doğru olduğunu gösteriyor.
2. **Erişimi kes, kanıtı silme:** 4G router'ın ağ kablosu çekilir. Router **kapatılmaz ve yeniden başlatılmaz**, çünkü bağlantı logları geçici bellekte olabilir (QE1).
3. **Gördüğünü kaydet:** Pano, HMI ekranı ve parametre ekranları fotoğraflanır. Kimin neye, ne zaman dokunduğu not edilir.

2 İlk 2 saat: Emniyet güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?

Nasıl doğrularız: PLC projesi ve invertör parametreleri **salt okunur** olarak dökülür. Devreye almadaki onaylı referansla karşılaştırılır (CRC ve parametre listesi). Bulunan her fark, LAB 4'teki bağımsızlık modelinde bir saldırıya çevrilir. Sonra acil stopun bandı yine güvenli mesafede durdurup durdurmadığına bakılır.

Ayar	Referans	Okunan	Fark
`plc_proje_crc`	7A3F-19C2	C04D-88E1	**evet**
`emniyet_rolesi_ayar`	SS1-t 1,0 s	SS1-t 1,0 s	hayır
`rampa_suresi`	0,5	10,0	**evet**
`hiz_carpani`	1,0	1,0	hayır

Emniyet mimarisi	Fark → LAB 4 saldırısı	Durma mesafesi	Emniyet güvende mi?
Emniyet kararı PLC'de, durdurma invertör rampasıyla	PLC mantığı değişti (acil stop yok sayılır)	bant durmaz	**Hayır**
Emniyet kararı PLC'de, durdurma invertör rampasıyla	İnvertör rampası 10 s	2,875 m	**Hayır**
Kablolu emniyet rölesi, SS1-t ile STO	PLC mantığı değişti (acil stop yok sayılır)	0,500 m	Evet
Kablolu emniyet rölesi, SS1-t ile STO	İnvertör rampası 10 s	0,931 m	Evet
Emniyet rölesi + SS1-t + emniyet tarafında hız izleme	PLC mantığı değişti (acil stop yok sayılır)	0,500 m	Evet
Emniyet rölesi + SS1-t + emniyet tarafında hız izleme	İnvertör rampası 10 s	0,931 m	Evet

Güvenli mesafe 1,50 m. Mevcut (varsayım) mimari bağımlı varyanttır.

Sonuç: mevcut mimaride emniyet güvende değil. PLC projesi değişmiş ve rampa 10 s'ye çıkmış. Acil stop basıldığında bant ya hiç durmuyor ya da 2,875 m kayıyor. Q1'deki "önce durdur" kararı bu yüzden doğru. Bağımsız emniyet mimarisinde aynı farklar SF1'i bozmuyor (0,931 m). Orada hat yine de durdurulur, ama bunun nedeni üretim konfigürasyonunun bütünlüğüdür, insanın korunması değil.

Korunan kanıt (her birinin özet değeri / hash kaydedilir):

Kimlik	Kanıt	Neden önemli
K1	PLC projesi + CRC	Neyin değiştiğinin ana kanıtı; geri yükleme bunu siler
K2	İnvertör parametre dökümü	Rampa / hız değişikliği; fabrika ayarına dönüş bunu siler
K3	Router / VPN bağlantı logları	Giriş saati, kaynak IP; yeniden başlatma bunu silebilir
K4	HMI olay logları + uzak masaüstü logları	Saldırganın hatta ne yaptığı
K5	Fotoğraflar	Ekranların ilk hâli
K6	Servis hesabının giriş kayıtları (üretici tarafı)	Hesabın nereden, ne zaman kullanıldığı

Kapatılan hesaplar: Paylaşılan servis hesabı (Efo tarafında, +01:00). Aynı parolayı paylaşan diğer hesaplar: router yönetimi, HMI ve uzak masaüstü aracı. Kalıcı çözüm kişisel hesap + MFA'dır (LAB 4). Paylaşılan hesap, "kim girdi?" sorusunu cevapsız bırakır.

3 24 saat — CRA erken uyarı: Hangi bilgi hazır olmalı?

CRA md. 14(4)(a) uyarınca, ürünün güvenliğini etkileyen ağır bir olayda erken uyarı en az şunları içerir [Y22]:

- Olayın hukuka aykırı ya da kötü niyetli bir eylemden kaynaklandığı şüphesi (K6: tanınmayan konumdan gece girişi).
- Etkilenen ürün ve kurulum (K1).
- Ürünün bulunduğu üye devletler; Efo'nun diğer müşterileri de aynı hesabı kullanıyor mu? (+03:00 değerlendirmesi).

Bildirim, üreticinin koordinatör CSIRT'üne ve ENISA'ya tek bildirim platformu üzerinden yapılır [Y22].

4 72 saat — CRA bildirim: Kök neden, etki, önlem — kim ne yapıyor?

Olay bildirimi; olayın genel niteliğini, ilk değerlendirmeyi, alınan düzeltici önlemleri ve kullanıcıların alabileceği önlemleri içerir [Y22].

Kim	Ne yapıyor	Bildirimdeki karşılığı
Üretici (Efo)	Kök neden: giriş yolu, değişen parametreler, aynı hesabın kullanıldığı diğer kurulumlar. Bildirimi gönderir; etkilenen kullanıcıları bilgilendirir [Y22].	Niteliği, kullanıcı önlemleri
OT güvenlik	K1–K4 analizi; zaman çizgisi	Olayın genel niteliği
Bakım + İSG	Emniyet değerlendirmesi; referanstan geri yükleme; SF1–SF4 testi + durma süresi ölçümü; sonra reset ve start	İlk değerlendirme: ciddiyet ve etki
Müşteri yönetimi	Üretim kaybı, iletişim, sigorta	—

Geri yükleme kanıt alındıktan sonra yapılır (+1 gün). Start, emniyet fonksiyon testinden sonra verilir.

5 14 gün — son rapor: Hangi loglar/kayıtlar korunmuş olmalı?

- K1–K6 ve her birinin hash'i.
- Zaman çizgisi (kim, neye, ne zaman dokundu) ve kanıtın el değiştirme kaydı.
- Referans konfigürasyon, olay anı dökümü ve geri yükleme sonrası yeni CRC.
- SF1–SF4 fonksiyon testi ve durma süresi ölçüm raporu.
- Uygulanan ve süren önlemler: kişisel hesaplar, MFA, varsayılan kapalı uzak erişim.

Süre notu: Föy 14 gün diyor. CRA'da 14 gün, **aktif olarak istismar edilen bir zafiyet** için düzeltici önlemin hazır olmasından sonraki süredir. **Ağır olayda** son rapor, olay bildiriminden sonra **bir ay** içinde verilir [Y22] SEKTÖR-TİPİK. Bu akış iki süreyi de karşılıyor (son rapor +12,5 gün).

En sık hata: "Resetleyip devam edelim." O düğme kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt. Model bunu bir karşı örnekle test ediyor: reset akışında kanıt kontrolü, emniyet sırası, start koşulu ve CRA paketleri kalıyor.

Kanıt: simülasyon (LAB 6)

Eğitim amaçlı modeldir; gerçek bir olay müdahale planı ya da hukuki görüş değildir. Senaryo ve konfigürasyon değerleri varsayımdır.

6.2 Akış. Her eylemin zamanı, sorumlusu, türü ve aldığı ya da sildiği kanıt:

Aşama	Zaman	Kim	Eylem	Tür	Kanıt
İlk 15 dk	+00:00	Vardiya sorumlusu	Bant başındaki operatöre haber: besleme ağzından uzak dur, hattı izle	emniyet	—

Aşama	Zaman	Kim	Eylem	Tür	Kanıt
İlk 15 dk	+00:02	Vardiya sorumlusu	Bakım/otomasyon sorumlusu, İSG uzmanı ve BT/OT güvenlik sorumlusunu ara	iletisim	—
İlk 15 dk	+00:05	Bakım sorumlusu	Hattı normal stop ile kontrollü durdur; ana şalteri kilitle (LOTO). Reset yok	emniyet	—
İlk 15 dk	+00:08	Bakım sorumlusu	4G router'ın ağ kablosunu çek (kapatma, yeniden başlatma yok)	erisim	—
İlk 15 dk	+00:10	Vardiya sorumlusu	Pano, HMI ve parametre ekranlarını fotoğrafla	kanit	alır K5
İlk 15 dk	+00:12	Vardiya sorumlusu	Üreticiyi (Efo) bilinen telefon numarasından ara; ele geçirilen kanal kullanılmaz	iletisim	—
İlk 2 saat	+00:30	OT güvenlik	PLC projesini ve CRC'yi salt okunur dök; referansla karşılaştır	kanit	alır K1
İlk 2 saat	+00:40	OT güvenlik	İnvertör parametrelerini dök	kanit	alır K2
İlk 2 saat	+00:50	OT güvenlik	Router loglarını ve HMI loglarını dışa aktar; özet değerlerini (hash) kaydet	kanit	alır K3, alır K4
İlk 2 saat	+01:00	Üretici (Efo)	Paylaşılan servis hesabını kapat; giriş kayıtlarını dışa aktar	erisim	alır K6
İlk 2 saat	+01:15	Bakım + İSG	Emniyet değerlendirmesi: konfigürasyon farkı → durma mesafesi (6.1)	emniyet	—
İlk 2 saat	+01:30	Vardiya sorumlusu	Olay kaydını aç: zaman çizgisi, kanıt listesi, kim neye dokundu	kanit	—
24 saate kadar	+03:00	Üretici (Efo)	Aktif istismar ya da ağır olay mı? CRA kapsamına giriyor mu? Etkilenen müşteriler	bildirim	—
24 saate kadar	+20:00	Üretici (Efo)	CRA erken uyarı (CSIRT + ENISA, tek bildirim platformu)	bildirim	—
24 saate kadar	+1 g 00:00	Bakım + OT güvenlik	Referans yedekten PLC ve invertörü geri yükle	kurtarma	**siler K1**, **siler K2**
72 saate kadar	+1 g 01:00	Bakım + İSG	SF1–SF4 fonksiyon testi + durma süresi ölçümü; sonra reset ve start	emniyet	—
72 saate kadar	+2 g 00:00	Üretici (Efo)	Kök neden analizi: giriş yolu, değişen parametreler, etkilenen kurulumlar	bildirim	—
72 saate kadar	+2 g 18:40	Üretici (Efo)	CRA olay bildirimi: genel bilgi, olayın niteliği, alınan ve kullanıcıya önerilen önlemler	bildirim	—
14 güne kadar	+7 g 00:00	Üretici + müşteri	Kişisel hesaplar + MFA + varsayılan kapalı uzak erişim (LAB 4 hedefi)	kurtarma	—
14 güne kadar	+12 g 12:00	Üretici (Efo)	CRA son rapor: ayrıntılı açıklama, ciddiyet, kök neden, uygulanan ve süren önlemler	bildirim	—

Zaman 10:15'ten itibaren (+gün sa:dk). Kanıt kimlikleri:

- **K1:** PLC projesi + CRC (salt okunur çevrimiçi döküm)
- **K2:** İnvertör parametre dökümü
- **K3:** Router / VPN bağlantı logları
- **K4:** HMI olay logları + uzak masaüstü aracı logları
- **K5:** Pano, HMI ekranı ve parametre ekranlarının fotoğrafı
- **K6:** Servis hesabının giriş kayıtları (üretici tarafı)

Kontroller: Bu akış ile "resetleyip devam edelim" akışı aynı kontrollerden geçirildi.

Kontrol	Bu akış	"Resetleyip devam edelim"
Kanıt, silinmeden önce alınıyor	✔	✘
İlk eylem emniyet; kurtarmadan önce emniyet değerlendirmesi	✔	✘
Servis hesabı 2 saat içinde kapanıyor	✔	✔
Start, emniyet fonksiyon testinden sonra	✔	✘

6.3 CRA paketleri. Her bilgi, süresinden önce tamamlanan bir eylemden ya da kanıttan geliyor mu?

Paket	Bilgi	Kaynağı	Hazır olduğu an	Süre içinde
24 sa — erken uyarı (≤ +1 g 00:00)	Kötü niyetli ya da hukuka aykırı eylem şüphesi	K6	+01:00	✔
24 sa — erken uyarı (≤ +1 g 00:00)	Etkilenen ürün ve kurulum	K1	+00:30	✔
24 sa — erken uyarı (≤ +1 g 00:00)	Ürünün bulunduğu üye devletler	Aktif istismar ya da ağır olay mı	+03:00	✔
72 sa — olay bildirimi (≤ +3 g 00:00)	Olayın genel niteliği	K1, K2, K3	+00:50	✔
72 sa — olay bildirimi (≤ +3 g 00:00)	İlk değerlendirme: ciddiyet ve etki	Emniyet değerlendirmesi	+01:15	✔
72 sa — olay bildirimi (≤ +3 g 00:00)	Alınan düzeltici / azaltıcı önlemler	Paylaşılan servis hesabını kapat, 4G router'ın ağ kablosunu çek	+01:00	✔
72 sa — olay bildirimi (≤ +3 g 00:00)	Kullanıcıların alabileceği önlemler	Kök neden analizi	+2 g 00:00	✔
14 gün — son rapor (≤ +14 g 00:00)	Ayrıntılı açıklama, ciddiyet ve etki	Kök neden analizi, SF1–SF4 fonksiyon testi	+2 g 00:00	✔
14 gün — son rapor (≤ +14 g 00:00)	Tehdit türü ya da kök neden	Kök neden analizi, K3, K4, K6	+2 g 00:00	✔
14 gün — son rapor (≤ +14 g 00:00)	Uygulanan ve süren önlemler	Kişisel hesaplar + MFA	+7 g 00:00	✔

Test sonuçları:

#	Test (dosya)	Sonuç
1	`test_referansla_karsilastirma_degisen_ayarlari_bulur` (test_lab6_incident)	✔ geçti
2	`test_fark_yoksa_emniyet_guvende` (test_lab6_incident)	✔ geçti
3	`test_mevcut_bagimli_mimaride_okunan_konfigurasyonla_emniyet_guvende_degil` (test_lab6_incident)	✔ geçti
4	`test_bagimsiz_emniyette_ayni_farklarla_acil_stop_guvenli_durdurur` (test_lab6_incident)	✔ geçti (2/2)
5	`test_emniyet_rolesi_ayari_degismisse_hicbir_mimaride_guvenilmez` (test_lab6_incident)	✔ geçti
6	`test_kanit_silinmeden_once_alinir` (test_lab6_incident)	✔ geçti
7	`test_resetleyip_devam_etmek_kaniti_siler` (test_lab6_incident)	✔ geçti
8	`test_ilk_eylem_emniyet_ve_kurtarmadan_once_emniyet_degerlendirmesi` (test_lab6_incident)	✔ geçti
9	`test_ilk_15_dakikada_hat_durdurulur_ve_uzak_baglanti_kesilir` (test_lab6_incident)	✔ geçti
10	`test_servis_hesabi_ilk_iki_saatte_kapanir` (test_lab6_incident)	✔ geçti
11	`test_start_emniyet_fonksiyon_testinden_once_verilmez` (test_lab6_incident)	✔ geçti
12	`test_her_kanit_kimligi_tanimli` (test_lab6_incident)	✔ geçti
13	`test_cra_paketindeki_her_bilgi_suresinden_once_hazir` (test_lab6_incident)	✔ geçti (3/3)

#	Test (dosya)	Sonuç
14	`test_reset_akisi_cra_paketlerini_dolduramaz` (test_lab6_incident)	✔ geçti

Yorum: Emniyet doğrulaması, LAB 1 ve LAB 4'teki durma mesafesi modelini olay anında kullanıyor. Bu yüzden "emniyet güvende mi?" sorusu bir tahmin değil, ölçülebilir bir karşılaştırma. Hazırlıksız bir hatta bu mümkün değil: onaylı bir referans konfigürasyon ve CRC yoksa karşılaştıracak bir şey de yoktur (QE2).

Ek sorular: zafiyetler ve nasıl kapatılır

> Föy dışıdır; kullanıcı isteğiyle eklendi. Öneriler genel sektör pratiğidir; Efo'nun bunları uygulayıp uygulamadığı bilinmiyor.

E1 Router'ı kapatmak yerine neden kablosunu çekiyoruz?

- **Zafiyet:** Birçok küçük router ve VPN cihazı bağlantı loglarını geçici bellekte tutar. Kapatmak ya da yeniden başlatmak giriş saatini ve kaynak IP'yi siler ÇIKARIM.
- **Kapatma:** Olay anında bağlantıyı fiziksel olarak kesip cihazı açık bırakmak. Kalıcı çözüm, logları cihazdan ayrı ve değiştirilemez bir yerde tutmaktır (LAB 4 QE1) [Y26, Y31] SEKTÖR-TİPİK.

E2 Olaydan önce neyin hazır olması gerekirdi?

- **Zafiyet:** Referans konfigürasyon yoksa "PLC değişti mi?" sorusunun cevabı yoktur. İletişim listesi yoksa ilk 15 dakika telefon numarası aramakla geçer.
- **Kapatma** [Y31] SEKTÖR-TİPİK:
  - Devreye almada PLC, emniyet rölesi ve invertör için onaylı yedek ve CRC; makineden ayrı saklanır.
  - Rolleriyle birlikte bir iletişim listesi ve üreticinin doğrulanmış numarası.
  - Bu föydeki akışın bir sayfalık kartı panonun kapağında.
  - Yılda bir tatbikat.

E3 Bağımsız emniyet olay müdahalesini nasıl değiştirir?

- **Bulgu:** Bağımlı mimaride emniyet doğrulanana kadar hat durmak zorunda. Bağımsız mimaride SF1 aynı farklarla güvenli kalıyor (6.1); karar insanın korunmasından çok üretim bütünlüğüne dayanıyor ÇIKARIM.
- **Sonuç:** Emniyetin bağımsızlığı, olayın etkisini bir emniyet olayından bir kullanılabilirlik olayına indiriyor. LAB 5'teki yama kararında da aynı etki görüldü.

Ek — Kod

efo_sim/lab6_incident.py

```python
"""LAB 6 — CRA olay simülasyonu (eğitim amaçlı).

6.1 Emniyet doğrulaması: olay sırasında salt okunur alınan konfigürasyon, onaylı referansla
    karşılaştırılır; fark LAB 4 bağımsızlık modelinde bir saldırıya çevrilir ve acil stop
    yine güvenli duruma götürüyor mu diye bakılır.
6.2 Zaman çizgisi: eylemler, kanıtı silen eylemlerden önce kanıt alınmış mı, emniyet ilk mi,
    hesap 2 saat içinde kapanmış mı? "Resetleyip devam edelim" akışı karşı örnek olarak tutulur.
6.3 CRA paketleri: 24 sa / 72 sa / 14 gün için gereken her bilgi, süresinden önce tamamlanan
    bir eylemden geliyor mu?

Çalıştırma (repo kökünden):  python -m efo_sim.lab6_incident
"""
import math

from efo_sim import lab4_attack as lab4
from efo_sim.params import OUT_DIR, bolum_metni, d, sayi

# ---------------------------------------------------------------- 6.1 Emniyet doğrulaması
FARK_SALDIRI = {  # konfigürasyon farkı → LAB 4'teki saldırı karşılığı
    "plc_proje_crc": "plc_mantigi",
    "rampa_suresi": "rampa",
    "hiz_carpani": "hiz_rampa",
}
```

```
24
25
26 def konfig_farki(referans=None, okunan=None):
27     referans = referans or d("lab6.referans_konfig")
28     okunan = okunan or d("lab6.okunan_konfig")
29     return [k for k in referans if referans[k] != okunan[k]]
30
31
32 def emniyet_degerlendirmesi(varyant, fark=None):
33     """Her fark için acil stop sonucu; en kötüsü belirleyicidir. Emniyet rölesi ayarı değiştiyse güven yok."""
34     fark = konfig_farki() if fark is None else fark
35     if "emniyet_rolesi_ayar" in fark:
36         return {"guvende": False, "neden": "emniyet rölesi ayarı referanstan farklı", "sonuclar": {}}
37     saldirilar = sorted({FARK_SALDIRI[f] for f in fark}) or ["yok"]
38     sonuclar = {sa: lab4.acil_stop_sonucu(varyant, sa) for sa in saldirilar}
39     kotu = [sa for sa, r in sonuclar.items() if r["ulasir"]]
40     neden = ("; ".join(lab4.SALDIRI_ADI[sa] for sa in kotu) + " → el besleme ağzına ulaşır") if kotu \
41         else "her farkta acil stop güvenli mesafede durduruyor"
42     return {"guvende": not kotu, "neden": neden, "sonuclar": sonuclar}
43
44
45 # ------------------------------------------------------------------ 6.2 Zaman çizgisi
46 KANITLAR = {
47     "K1": "PLC projesi + CRC (salt okunur çevrimiçi döküm)",
48     "K2": "İnvertör parametre dökümü",
49     "K3": "Router / VPN bağlantı logları",
50     "K4": "HMI olay logları + uzak masaüstü aracı logları",
51     "K5": "Pano, HMI ekranı ve parametre ekranlarının fotoğrafı",
52     "K6": "Servis hesabının giriş kayıtları (üretici tarafı)",
53 }
54
55 # (dakika, kim, eylem, kategori, alınan kanıtlar, silinen kanıtlar)
56 AKIS = [
57     (0, "Vardiya sorumlusu", "Bant başındaki operatöre haber: besleme ağzından uzak dur, hattı izle", "emniyet",
[], []),
58     (2, "Vardiya sorumlusu", "Bakım/otomasyon sorumlusu, İSG uzmanı ve BT/OT güvenlik sorumlusunu ara", "iletisim
", [], []),
59     (5, "Bakım sorumlusu", "Hattı normal stop ile kontrollü durdur; ana şalteri kilitle (LOTO). Reset yok", "emn
iyet", [], []),
60     (8, "Bakım sorumlusu", "4G router'ın ağ kablosunu çek (kapatma, yeniden başlatma yok)", "erisim", [], []),
61     (10, "Vardiya sorumlusu", "Pano, HMI ve parametre ekranlarını fotoğrafla", "kanit", ["K5"], []),
62     (12, "Vardiya sorumlusu", "Üreticiyi (Efo) bilinen telefon numarasından ara; ele geçirilen kanal
kullanılmaz", "iletisim", [], []),
63     (30, "OT güvenlik", "PLC projesini ve CRC'yi salt okunur dök; referansla karşılaştır", "kanit", ["K1"], []),
64     (40, "OT güvenlik", "İnvertör parametrelerini dök", "kanit", ["K2"], []),
65     (50, "OT güvenlik", "Router loglarını ve HMI loglarını dışa aktar; özet değerlerini (hash) kaydet", "kanit",
["K3", "K4"], []),
66     (60, "Üretici (Efo)", "Paylaşılan servis hesabını kapat; giriş kayıtlarını dışa aktar", "erisim", ["K6"], [])
,
67     (75, "Bakım + İSG", "Emniyet değerlendirmesi: konfigürasyon farkı → durma mesafesi (6.1)", "emniyet", [], [])
,
68     (90, "Vardiya sorumlusu", "Olay kaydını aç: zaman çizgisi, kanıt listesi, kim neye dokundu", "kanit", [], [])
,
69     (180, "Üretici (Efo)", "Aktif istismar ya da ağır olay mı? CRA kapsamına giriyor mu? Etkilenen müşteriler", "
bildirim", [], []),
70     (1200, "Üretici (Efo)", "CRA erken uyarı (CSIRT + ENISA, tek bildirim platformu)", "bildirim", [], []),
71     (1440, "Bakım + OT güvenlik", "Referans yedekten PLC ve invertörü geri yükle", "kurtarma", [], ["K1", "K2"]),
72     (1500, "Bakım + İSG", "SF1-SF4 fonksiyon testi + durma süresi ölçümü; sonra reset ve start", "emniyet", [], [
]),
73     (2880, "Üretici (Efo)", "Kök neden analizi: giriş yolu, değişen parametreler, etkilenen kurulumlar", "bildir
im", [], []),
74     (4000, "Üretici (Efo)", "CRA olay bildirimi: genel bilgi, olayın niteliği, alınan ve kullanıcıya önerilen
önlemler", "bildirim", [], []),
75     (10080, "Üretici + müşteri", "Kişisel hesaplar + MFA + varsayılan kapalı uzak erişim (LAB 4 hedefi)", "kurta
rma", [], []),
76     (18000, "Üretici (Efo)", "CRA son rapor: ayrıntılı açıklama, ciddiyet, kök neden, uygulanan ve süren
önlemler", "bildirim", [], []),
77 ]
78
79 # Föydeki en sık hata: önce reset, sonra her şey
80 AKIS_RESET = [
81     (0, "Vardiya sorumlusu", "Router'ı ve HMI'yı yeniden başlat, PLC'yi yedekten yükle, hattı resetleyip
çalıştır",
82      "kurtarma", [], ["K1", "K2", "K3", "K4"]),
83     (30, "Vardiya sorumlusu", "Bakım sorumlusunu ara", "iletisim", [], []),
84     (60, "Bakım sorumlusu", "Logları ve parametreleri topla", "kanit", ["K1", "K2", "K3", "K4"], []),
85     (120, "Üretici (Efo)", "Servis hesabını kapat", "erisim", ["K6"], []),
86 ]
```

```python

HESAP_KAPATMA = "Paylaşılan servis hesabını kapat"


def kanit_korunur(akis):
    """Kanıtı silen her eylemden önce o kanıt alınmış olmalı."""
    alinan = set()
    for _, _, _, _, al, sil in sorted(akis, key=lambda e: e[0]):
        if any(k not in alinan for k in sil):
            return False
        alinan |= set(al)
    return True


def emniyet_ilk(akis):
    """İlk eylem emniyet olmalı; ilk kurtarma eyleminden önce emniyet değerlendirmesi yapılmış olmalı."""
    sirali = sorted(akis, key=lambda e: e[0])
    if sirali[0][3] != "emniyet":
        return False
    kurtarma = [e[0] for e in sirali if e[3] == "kurtarma"]
    degerlendirme = [e[0] for e in sirali if e[3] == "emniyet" and "değerlendirme" in e[2].lower()]
    return not kurtarma or (bool(degerlendirme) and degerlendirme[0] < kurtarma[0])


def hesap_kapatma_dakikasi(akis):
    return next((e[0] for e in akis if HESAP_KAPATMA in e[2] or "Servis hesabını kapat" in e[2]), math.inf)


def yeniden_baslatma_testten_sonra(akis):
    """Start, emniyet fonksiyon testinden önce verilmemeli."""
    for t, _, eylem, _, _, _ in akis:
        if "start" in eylem.lower() or "çalıştır" in eylem.lower():
            if not any("fonksiyon testi" in e[2] and e[0] <= t for e in akis):
                return False
    return True


# ---------------------------------------------------------------- 6.3 CRA paketleri
# Bilgi alanı → hangi eylemden ya da kanıttan gelir (CRA md. 14; Y22)
CRA_PAKETLERI = {
    "erken_uyari": {
        "Kötü niyetli ya da hukuka aykırı eylem şüphesi": ["K6"],
        "Etkilenen ürün ve kurulum": ["K1"],
        "Ürünün bulunduğu üye devletler": ["Aktif istismar ya da ağır olay mı"],
    },
    "bildirim": {
        "Olayın genel niteliği": ["K1", "K2", "K3"],
        "İlk değerlendirme: ciddiyet ve etki": ["Emniyet değerlendirmesi"],
        "Alınan düzeltici / azaltıcı önlemler": [HESAP_KAPATMA, "4G router'ın ağ kablosunu çek"],
        "Kullanıcıların alabileceği önlemler": ["Kök neden analizi"],
    },
    "son_rapor": {
        "Ayrıntılı açıklama, ciddiyet ve etki": ["Kök neden analizi", "SF1-SF4 fonksiyon testi"],
        "Tehdit türü ya da kök neden": ["Kök neden analizi", "K3", "K4", "K6"],
        "Uygulanan ve süren önlemler": ["Kişisel hesaplar + MFA"],
    },
}
PAKET_ADI = {"erken_uyari": "24 sa — erken uyarı", "bildirim": "72 sa — olay bildirimi", "son_rapor": "14 gün — son rapor"}


def kaynak_tamam_dk(akis, kaynak):
    """Bir kanıt kimliği ya da eylem metni parçası akışta en erken ne zaman tamamlanıyor?"""
    for t, _, eylem, _, al, _ in sorted(akis, key=lambda e: e[0]):
        if kaynak in al or kaynak in eylem:
            return t
    return math.inf


def cra_hazirlik(akis=AKIS):
    """Her paket için: alan → (en geç tamamlanma dakikası, süre içinde mi)."""
    sonuc = {}
    for paket, alanlar in CRA_PAKETLERI.items():
        sinir = d("lab6.kilometre_taslari")[paket]
        sonuc[paket] = {}
        for alan, kaynaklar in alanlar.items():
            t = max(kaynak_tamam_dk(akis, k) for k in kaynaklar)
            sonuc[paket][alan] = (t, t <= sinir)
```

```
    return sonuc


# ---------------------------------------------------------------- Çıktılar
def saat_metni(dk):
    if math.isinf(dk):
        return "yok"
    gun, kalan = divmod(int(dk), 1440)
    sa, mn = divmod(kalan, 60)
    return (f"+{gun} g " if gun else "+") + f"{sa:02d}:{mn:02d}"


def akis_md():
    kt = d("lab6.kilometre_taslari")
    asamalar = [(kt["ilk_mudahale"], "İlk 15 dk"), (kt["ilk_asama"], "İlk 2 saat"), (kt["erken_uyari"],
"24 saate kadar"),
                (kt["bildirim"], "72 saate kadar"), (kt["son_rapor"], "14 güne kadar")]
    s = ["| Aşama | Zaman | Kim | Eylem | Tür | Kanıt |", "|---|---|---|---|---|---|"]
    for t, kim, eylem, tur, al, sil in AKIS:
        asama = next(ad for sinir, ad in asamalar if t <= sinir)
        kanit = ", ".join([f"alır {k}" for k in al] + [f"**siler {k}**" for k in sil]) or "—"
        s.append(f"| {asama} | {saat_metni(t)} | {kim} | {eylem} | {tur} | {kanit} |")
    s += ["", "Zaman 10:15'ten itibaren (+gün sa:dk). Kanıt kimlikleri:", ""]
    s += [f"- **{k}:** {v}" for k, v in KANITLAR.items()]
    return "\n".join(s) + "\n"


def _deger(x):
    return sayi(x, 1) if isinstance(x, float) else x


def emniyet_md():
    fark = konfig_farki()
    ref, ok = d("lab6.referans_konfig"), d("lab6.okunan_konfig")
    s = ["| Ayar | Referans | Okunan | Fark |", "|---|---|---|---|"]
    for k in ref:
        s.append(f"| `{k}` | {_deger(ref[k])} | {_deger(ok[k])} | {'**evet**' if k in fark else 'hayır'} |")
    s += ["", "| Emniyet mimarisi | Fark → LAB 4 saldırısı | Durma mesafesi | Emniyet güvende mi? |", "|---|---|---
--|---|"]
    for v, vad in lab4.VARYANTLAR.items():
        e = emniyet_degerlendirmesi(v, fark)
        for sa, r in e["sonuclar"].items():
            mesafe = "bant durmaz" if math.isinf(r["mesafe"]) else f"{sayi(r['mesafe'], 3)} m"
            s.append(f"| {vad} | {lab4.SALDIRI_ADI[sa]} | {mesafe} | {'Evet' if not r['ulasir'] else
'**Hayır**'} |")
    s += ["", f"Güvenli mesafe {sayi(d('lab1.guvenli_mesafe'))} m. Mevcut (varsayım) mimari bağımlı varyanttır."]
    return "\n".join(s) + "\n"


def kontrol_md():
    satirlar = [("Kanıt, silinmeden önce alınıyor", kanit_korunur),
                ("İlk eylem emniyet; kurtarmadan önce emniyet değerlendirmesi", emniyet_ilk),
                ("Servis hesabı 2 saat içinde kapanıyor",
                 lambda a: hesap_kapatma_dakikasi(a) <= d("lab6.kilometre_taslari")["ilk_asama"]),
                ("Start, emniyet fonksiyon testinden sonra", yeniden_baslatma_testten_sonra)]
    s = ["| Kontrol | Bu akış | \"Resetleyip devam edelim\" |", "|---|---|---|"]
    for ad, f in satirlar:
        s.append(f"| {ad} | {'✓' if f(AKIS) else 'X'} | {'✓' if f(AKIS_RESET) else '**X**'} |")
    return "\n".join(s) + "\n"


def cra_md():
    h = cra_hazirlik()
    kt = d("lab6.kilometre_taslari")
    s = ["| Paket | Bilgi | Kaynağı | Hazır olduğu an | Süre içinde |", "|---|---|---|---|---|"]
    for paket, alanlar in CRA_PAKETLERI.items():
        for alan, kaynaklar in alanlar.items():
            t, ok = h[paket][alan]
            s.append(f"| {PAKET_ADI[paket]} (≤ {saat_metni(kt[paket])}) | {alan} | {', '.join(kaynaklar)} | "
                     f"{saat_metni(t)} | {'✓' if ok else '**X**'} |")
    return "\n".join(s) + "\n"


def _grafik_zaman(yol):
    import matplotlib
    matplotlib.use("Agg")
    import matplotlib.pyplot as plt

```

```
    turler = ["emniyet", "kanit", "erisim", "iletisim", "kurtarma", "bildirim"]
    adlar = {"emniyet": "Emniyet", "kanit": "Kanıt", "erisim": "Erişim", "iletisim": "İletişim",
             "kurtarma": "Kurtarma", "bildirim": "Bildirim"}
    renk = {"emniyet": "#b3261e", "kanit": "#2a78d6", "erisim": "#eb6834", "iletisim": "#9aa3b2",
            "kurtarma": "#1baf7a", "bildirim": "#7a4fd0"}
    fig, ax = plt.subplots(figsize=(7.4, 3.4), dpi=200)
    for t, _, _, tur, _, sil in AKIS:
        y = turler.index(tur)
        ax.plot(max(t, 1), y, "o", ms=7 if not sil else 9, color=renk[tur],
                mec="#16223a" if sil else "white", mew=1.5)
    kt = d("lab6.kilometre_taslari")
    for anahtar, ad in (("ilk_mudahale", "15 dk"), ("ilk_asama", "2 sa"), ("erken_uyari", "24 sa"),
                        ("bildirim", "72 sa"), ("son_rapor", "14 gün")):
        ax.axvline(kt[anahtar], color="#16223a", lw=0.8, ls="--", alpha=0.6)
        ax.text(kt[anahtar], len(turler) - 0.35, ad, ha="center", fontsize=7.5, color="#16223a")
    ax.set_xscale("log")
    ax.set_xlim(0.8, kt["son_rapor"] * 1.6)
    ax.set_ylim(-0.6, len(turler) - 0.1)
    ax.set_yticks(range(len(turler)))
    ax.set_yticklabels([adlar[t] for t in turler], fontsize=8)
    ax.set_xticks([1, 10, 60, 600, 1440, 10080])
    ax.set_xticklabels(["+1 dk", "+10 dk", "+1 sa", "+10 sa", "+1 g", "+7 g"], fontsize=7.5)
    ax.set_title("Olay akışı (logaritmik zaman; koyu kenarlı nokta = kanıtı silen eylem)", fontsize=9.5, loc="le
ft")
    ax.grid(axis="x", alpha=0.2)
    ax.spines[["top", "right"]].set_visible(False)
    fig.tight_layout()
    fig.savefig(yol)
    plt.close(fig)


def main():
    OUT_DIR.mkdir(exist_ok=True)
    (OUT_DIR / "lab6_akis.md").write_text(akis_md(), encoding="utf-8")
    (OUT_DIR / "lab6_emniyet.md").write_text(emniyet_md(), encoding="utf-8")
    (OUT_DIR / "lab6_kontroller.md").write_text(kontrol_md(), encoding="utf-8")
    (OUT_DIR / "lab6_cra.md").write_text(cra_md(), encoding="utf-8")
    (OUT_DIR / "lab6_params.yaml").write_text(bolum_metni("lab6"), encoding="utf-8")
    _grafik_zaman(OUT_DIR / "lab6_zaman_cizelgesi.png")
    print(emniyet_md())
    print(kontrol_md())
    print(cra_md())


if __name__ == "__main__":
    main()
```

efo_sim/tests/test_lab6_incident.py

```
"""LAB 6 gereksinimleri = testler (eğitim amaçlı model)."""
import pytest

from efo_sim import lab6_incident as m


# ---------------------------------------------------------------- 6.1 Emniyet doğrulaması
def test_referansla_karsilastirma_degisen_ayarlari_bulur():
    assert set(m.konfig_farki()) == {"plc_proje_crc", "rampa_suresi"}


def test_fark_yoksa_emniyet_guvende():
    ref = m.d("lab6.referans_konfig")
    assert m.konfig_farki(ref, dict(ref)) == []
    assert m.emniyet_degerlendirmesi("bagimli", fark=[])["guvende"]


def test_mevcut_bagimli_mimaride_okunan_konfigurasyonla_emniyet_guvende_degil():
    assert not m.emniyet_degerlendirmesi("bagimli")["guvende"]


@pytest.mark.parametrize("varyant", ["bagimsiz", "bagimsiz_hiz_izlemeli"])
def test_bagimsiz_emniyette_ayni_farklarla_acil_stop_guvenli_durdurur(varyant):
    assert m.emniyet_degerlendirmesi(varyant)["guvende"]


def test_emniyet_rolesi_ayari_degismisse_hicbir_mimaride_guvenilmez():
    for v in m.lab4.VARYANTLAR:
        assert not m.emniyet_degerlendirmesi(v, fark=["emniyet_rolesi_ayar"])["guvende"]
```

```python


# ---------------------------------------------------------------- 6.2 Zaman çizgisi
def test_kanit_silinmeden_once_alinir():
    assert m.kanit_korunur(m.AKIS)


def test_resetleyip_devam_etmek_kaniti_siler():
    assert not m.kanit_korunur(m.AKIS_RESET)


def test_ilk_eylem_emniyet_ve_kurtarmadan_once_emniyet_degerlendirmesi():
    assert m.emniyet_ilk(m.AKIS)
    assert not m.emniyet_ilk(m.AKIS_RESET)


def test_ilk_15_dakikada_hat_durdurulur_ve_uzak_baglanti_kesilir():
    ilk = [e for e in m.AKIS if e[0] <= m.d("lab6.kilometre_taslari")["ilk_mudahale"]]
    assert any(e[3] == "emniyet" and "LOTO" in e[2] for e in ilk)
    assert any(e[3] == "erisim" for e in ilk)


def test_servis_hesabi_ilk_iki_saatte_kapanir():
    assert m.hesap_kapatma_dakikasi(m.AKIS) <= m.d("lab6.kilometre_taslari")["ilk_asama"]


def test_start_emniyet_fonksiyon_testinden_once_verilmez():
    assert m.yeniden_baslatma_testten_sonra(m.AKIS)
    assert not m.yeniden_baslatma_testten_sonra(m.AKIS_RESET)


def test_her_kanit_kimligi_tanimli():
    for e in m.AKIS + m.AKIS_RESET:
        assert set(e[4]) | set(e[5]) <= set(m.KANITLAR)


# ---------------------------------------------------------------- 6.3 CRA paketleri
@pytest.mark.parametrize("paket", list(m.CRA_PAKETLERI))
def test_cra_paketindeki_her_bilgi_suresinden_once_hazir(paket):
    for alan, (t, ok) in m.cra_hazirlik()[paket].items():
        assert ok, f"{paket} / {alan}: {t} dk"


def test_reset_akisi_cra_paketlerini_dolduramaz():
    h = m.cra_hazirlik(m.AKIS_RESET)
    assert not all(ok for alanlar in h.values() for _, ok in alanlar.values())
```

`params.yaml` — LAB 6 bölümü:

efo_sim/out/lab6_params.yaml

```yaml
lab6:
  kilometre_taslari:
    deger: {ilk_mudahale: 15, ilk_asama: 120, erken_uyari: 1440, bildirim: 4320, son_rapor: 20160}
    birim: "dk"
    etiket: "SEKTÖR-TİPİK"
    kaynak: "föy LAB 6, Y20, Y22"
    not: "10:15'ten itibaren: 15 dk, 2 sa, 24 sa, 72 sa, 14 gün"
  # Referans (onaylı) konfigürasyon ve olay sırasında okunan konfigürasyon
  referans_konfig:
    deger: {plc_proje_crc: "7A3F-19C2", emniyet_rolesi_ayar: "SS1-t 1,0 s", rampa_suresi: 0.5, hiz_carpani: 1.0}
    etiket: "VARSAYIM"
    kaynak: "V19"
    not: "Devreye almadaki onaylı yedek. Rampa lab1.rampa_suresi_kat1 ile aynı"
  okunan_konfig:
    deger: {plc_proje_crc: "C04D-88E1", emniyet_rolesi_ayar: "SS1-t 1,0 s", rampa_suresi: 10.0, hiz_carpani: 1.0}
    etiket: "VARSAYIM"
    kaynak: "V19"
    not: "Olay sırasında salt okunur olarak alınan döküm: PLC projesi farklı, rampa 10 s (LAB 3 saldırısı)"
```

pytest çıktısı:

efo_sim/out/pytest_lab6.txt

```
============================= test session starts ==============================
platform linux -- Python 3.14.8, pytest-9.0.2, pluggy-1.6.0 -- /usr/bin/python
rootdir: /home/ydogan/Masaüstü/safety40-efo-konveyor
```

```
configfile: pytest.ini
plugins: asyncio-1.3.0, anyio-4.13.0
asyncio: mode=Mode.STRICT, debug=False, asyncio_default_fixture_loop_scope=None,
asyncio_default_test_loop_scope=function
collecting ... collected 17 items

efo_sim/tests/test_lab6_incident.py::test_referansla_karsilastirma_degisen_ayarlari_bulur PASSED [  5%]
efo_sim/tests/test_lab6_incident.py::test_fark_yoksa_emniyet_guvende PASSED [ 11%]
efo_sim/tests/test_lab6_incident.py::test_mevcut_bagimli_mimaride_okunan_konfigurasyonla_emniyet_guvende_degil PASSED
[ 17%]
efo_sim/tests/test_lab6_incident.py::test_bagimsiz_emniyette_ayni_farklarla_acil_stop_guvenli_durdurur[bagimsiz]
PASSED [ 23%]
efo_sim/tests/
test_lab6_incident.py::test_bagimsiz_emniyette_ayni_farklarla_acil_stop_guvenli_durdurur[bagimsiz_hiz_izlemeli]
PASSED [ 29%]
efo_sim/tests/test_lab6_incident.py::test_emniyet_rolesi_ayari_degismisse_hicbir_mimaride_guvenilmez PASSED [ 35%]
efo_sim/tests/test_lab6_incident.py::test_kanit_silinmeden_once_alinir PASSED [ 41%]
efo_sim/tests/test_lab6_incident.py::test_resetleyip_devam_etmek_kaniti_siler PASSED [ 47%]
efo_sim/tests/test_lab6_incident.py::test_ilk_eylem_emniyet_ve_kurtarmadan_once_emniyet_degerlendirmesi PASSED [ 52%]
efo_sim/tests/test_lab6_incident.py::test_ilk_15_dakikada_hat_durdurulur_ve_uzak_baglanti_kesilir PASSED [ 58%]
efo_sim/tests/test_lab6_incident.py::test_servis_hesabi_ilk_iki_saatte_kapanir PASSED [ 64%]
efo_sim/tests/test_lab6_incident.py::test_start_emniyet_fonksiyon_testinden_once_verilmez PASSED [ 70%]
efo_sim/tests/test_lab6_incident.py::test_her_kanit_kimligi_tanimli PASSED [ 76%]
efo_sim/tests/test_lab6_incident.py::test_cra_paketindeki_her_bilgi_suresinden_once_hazir[erken_uyari] PASSED [ 82%]
efo_sim/tests/test_lab6_incident.py::test_cra_paketindeki_her_bilgi_suresinden_once_hazir[bildirim] PASSED [ 88%]
efo_sim/tests/test_lab6_incident.py::test_cra_paketindeki_her_bilgi_suresinden_once_hazir[son_rapor] PASSED [ 94%]
efo_sim/tests/test_lab6_incident.py::test_reset_akisi_cra_paketlerini_dolduramaz PASSED [100%]

============================== 17 passed in 0.04s ==============================
```

Kaynaklar

R = derin araştırma raporundaki kaynak numarası; Y = bu çalışmada eklenen kaynak.

- **Y22** Regulation (EU) 2024/2847 (Cyber Resilience Act), Article 14 — Reporting obligations of manufacturers — https://eur-lex.europa.eu/eli/reg/2024/2847/oj
- **Y26** NIST SP 800-82 Rev. 3 — Guide to Operational Technology (OT) Security — https://csrc.nist.gov/pubs/sp/800/82/r3/final
- **Y30** USOM — Ulusal Siber Olaylara Müdahale Merkezi — https://www.usom.gov.tr/
- **Y31** NIST SP 800-61 Rev. 3 — Incident Response Recommendations and Considerations for Cybersecurity Risk Management — https://csrc.nist.gov/pubs/sp/800/61/r3/final